



重要インフラのサードパーティAI サプライチェーンリスクマネジメント：医療のケース

May 26, 2026

@esasahara

Cloud Security Alliance Kansai Chapter
Health Information Management WG

(参考1) CSA STAR Registry & CSA STAR for AI

CSAcloud security alliance®

Membership ▾ STAR Program ▾ Education ▾ Research ▾ Strategic Initiatives ▾

CSAI CHAPTERS EVENTS BLOG SIGN IN OR SIGN UP

Learn to manage risk, governance, and resilience in agentic AI. Join us May 14 at 10:00 AM PDT for a 20-minute session with Rubrik's CTO. Register now →

STAR Registry Listing for

OpenAI API, ChatGPT Enterprise, ChatGPT Teams, ChatGPT Edu



STAR HOME REGISTRY SUBMIT TO REGISTRY CONTACT US RESOURCES STAR SOLUTIONS

Home > STAR > Registry > OpenAI > OpenAI API, ChatGPT Enterprise, ChatGPT Teams, ChatGPT Edu

OpenAI API, ChatGPT Enterprise, ChatGPT Teams, ChatGPT Edu

OpenAI Generative AI Products



Information about OpenAI API, ChatGPT Enterprise, ChatGPT Teams, ChatGPT Edu
Listed Since: 04/09/2024

STAR Level 1

Self-Assessment & Partner-Provided

Cloud Controls Matrix



CAIQ Self-assessment v4.0.2

Download CAIQ Self-assessment

Offers an industry-accepted way to document what security controls exist in IaaS, PaaS, and SaaS services. It provides a set of Yes/No/NA questions and space to justify the response a cloud consumer and cloud auditor may wish to ask of a cloud provider to ascertain their compliance to the Cloud Controls Matrix (CCM).

Created or renewed 10 months ago, on June 24, 2025.

CSAcloud security alliance®

Membership ▾ STAR Program ▾ Education ▾ Research ▾ Strategic Initiatives ▾

CSAI CHAPTERS EVENTS BLOG SIGN IN OR SIGN UP

Learn to manage risk, governance, and resilience in agentic AI. Join us May 14 at 10:00 AM PDT for a 20-minute session with Rubrik's CTO. Register now →

CSA STAR Registry

Security, Trust, Assurance, and Risk Registry

STAR HOME REGISTRY SUBMIT TO REGISTRY CONTACT US RESOURCES STAR SOLUTIONS

Home > STAR > Registry > Listings for Anthropic, PBC

Listings for Anthropic, PBC

AI will have a vast impact on the world. Anthropic is a public benefit corporation dedicated to securing its benefits and mitigating its risks.

ANTHROPIC

Anthropic, PBC

AI will have a vast impact on the world. Anthropic is a public benefit corporation dedicated to securing its benefits and mitigating its risks.

Listed Since: 2025-10-21

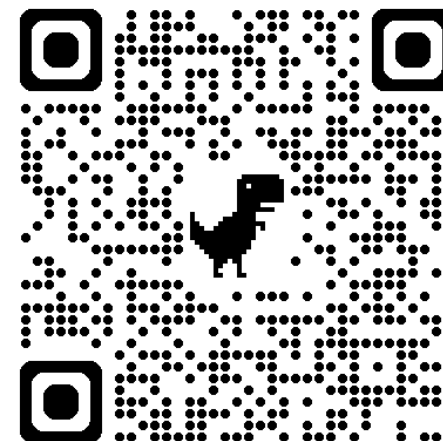
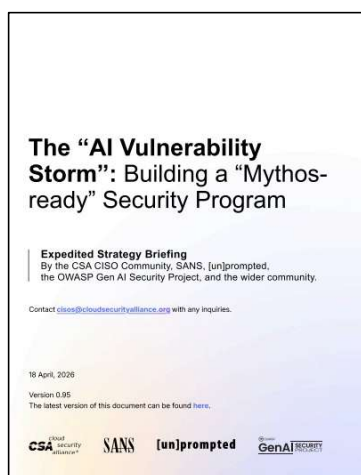


ISO/IEC 42001

View Listing

(参考2)CSA、SANS、[un]prompted, OWASP GenAI他「AI脆弱性の嵐：Mythosに対応可能なセキュリティプログラムの構築」(2026年4月発行)

本書は、AnthropicのAIモデル「Mythos」等がもたらす脅威に備えるための指針です。AIが脆弱性発見から悪用までを劇的に加速させ、発見から攻撃までの時間が数時間以内へ短縮された現状を指摘しています。企業は従来の対策から脱却し、AIを活用した防御や運用の自動化、継続的な脆弱性管理の導入が不可欠です。本書では、防衛側がAIと対等に渡り合うための実践的なフレームワークを示しています。





AGENDA

- 1. CSAの医療におけるサードパーティベンダーリスク管理の取り組み
- 2. 米国医療業界のサードパーティAIベンダーリスク管理の取り組み
- 3. まとめ・Q&A

1-1.CSA「医療におけるサードパーティベンダーリスク管理」 (2022年7月発行)

医療機関(HDO)において、リソースを中核業務へ集中させるためのサードパーティ活用は今後も拡大する見通しです。これに伴い、医療機関はビジネス目標に基づいたリスク評価を行い、適切なセキュリティ対策を講じる必要があります。特に、外部資産の「継続的なモニタリング」を導入することで、潜在的なリスクをリアルタイムで検知・軽減し、安全な委託環境を維持することが不可欠となっています。

医療機関
向け



1-2. 医療機関が認識すべきサードパーティベンダーのリスク

- サイバーセキュリティリスク：
サードパーティベンダーのサイバーセキュリティ制御の不備により、組織のデータの機密性、完全性、可用性が影響を受けるリスク
- レピュテーションリスク：
サードパーティベンダーが関与するインシデントが発生した場合、医療機関のブランドレピュテーションにネガティブな影響が及ぶリスク
- コンプライアンスリスク：
事業を遂行するために組織が従わなければならない法律や規制、内部プロセスの違反から生じるリスク
- プライバシーリスク：
サードパーティベンダーと共有する個人データに対する権限のないアクセスが可能となるリスク
- オペレーショナルリスク：
サードパーティベンダーの業務は医療機関の業務と絡み合っており、ベンダーのサービス提供ができなくなると医療機関も日常活動を遂行できなくなるリスク
- 戦略的リスク：
医療機関の戦略目標と合致しないビジネス意思決定をサードパーティベンダーが行った時に生じるリスク
- 財務リスク：
サードパーティベンダーが医療機関の収入に損失を与えるリスク（例．製品リコール）

1-3. サードパーティベンダーに対する評価のベストプラクティス

- サードパーティベンダーの分類：
ベンダーを分類する手法を開発し、個々のベンダーのリスク評価に割り当てる
- サードパーティ評価頻度の設定と固有のリスク評価に基づくスコープ：
サードパーティリスク評価は、一度限りのプロセスでなく、継続的なモニタリングや再評価を必要とする
- 認識された標準規格を利用したサードパーティ評価の実施：
評価をベンダーおよび内部ステークホルダーと共有し、ベンダーが課題に取組み、評価結果をリスク登録に記録することを保証する
- パフォーマンスの評価
- 財務リスクの評価
- 事業継続リスクの評価：
サードパーティが中断すると、事業継続のリスクとなる可能性がある

1-4. クラウドに関連する考慮事項

- **データセキュリティと制御**：

他のサードパーティ管理者とともに、医療機関は、クラウドベンダーの内部統制の強度を評価しなければならない。

- **データ転送**：

データは、インターネットや無線ネットワーク経由で転送される可能性がある。医療組織は、クラウドコンピューティングベンダーを選定する際に、すべての法令の要求事項を遵守しなければならない。データが転送・保存される場所を特定することを忘れてはならない。

- **マルチテナント性**：

これは、医療組織に対して、共有されたハードウェア上でデータが混じり合う可能性を考慮するよう求める。

- **ロケーション**：

データをクラウド上に移転することは、ハードウェアプロバイダーが制御できない遠隔地に資産を移転することを意味する。加えて、データは米国外に保存される可能性がある。

- **信頼性**：

クラウドのような共有リソースに依存する場合、医療組織は、必要な時にリソースが利用できないというリスクに直面する。

- **持続可能性**：

医療組織は、万一クラウドが故障した場合に業務を継続する手段を理解するために、クラウドプロバイダーの災害復旧・事業継続計画が適正であるかを判断すべきである。

1-5. サードパーティベンダーリスク管理自動化のメリット

- 効率性：
自動化プログラムは、効率的な評価時間、制御されたプロセス、一貫したワークフロー、正確な文書化を可能にする。
- 透明性：
すべてのサードパーティの記録をスクリーニング・モニタリングすることによって、医療提供組織は、現実のリスクに対応できる。自動化されたリスクベースのプログラムで重要なのは、適切にデータを利用し、リスクを上手に低減するためにリソースを適用することにある。
- ポリシーの組織化と分類：
文書へのアクセスを表すために利用する構造によって、文書を分類する。構造は検索可能である必要がある。
- 迅速な通知：
自動化プログラムは、違反やリスクを直ちに報告することができる。



AGENDA

- 1. CSAの医療におけるサードパーティベンダーリスク管理の取り組み
- **2. 米国医療業界のサードパーティAIベンダーリスク管理の取り組み**
- 3. まとめ・Q&A

2-1. 保健医療セクター調整委員会(HSCC)とは？

<https://healthsectorcouncil.org/>

・HSCCのミッション：

保健医療セクターの安全確保とレジリエンスに対するサイバーおよび物理的リスクを特定し、それらのリスクを軽減するためのガイダンスを策定すること、そして政府と連携して脅威への備えとインシデント対応を促進することにある

・HSCCの構成組織：

- ・医療提供者(病院、診療所、薬局、介護施設など；外部委託先含む)**
- ・医療保険者**
- ・医療機器・医薬品企業**
- ・保健医療ITベンダー**
- ・公衆衛生機関**
- ・保健医療分野の業界団体または専門職団体**

2-2. HSCCと保健医療ISAC／ISAOの関係

- HSCCの役割：

保健医療セクターのサイバーセキュリティに関する**戦略・政策・ガイドライン**の策定

活動：連邦政府機関(保健福祉省、国土安全保障省)との公式な窓口となり、セクター全体のサイバーセキュリティ向上に向けた中長期的な戦略や、規制に関する提言、ベストプラクティスの作成を行う

- 保健医療ISAC／ISAOの役割：

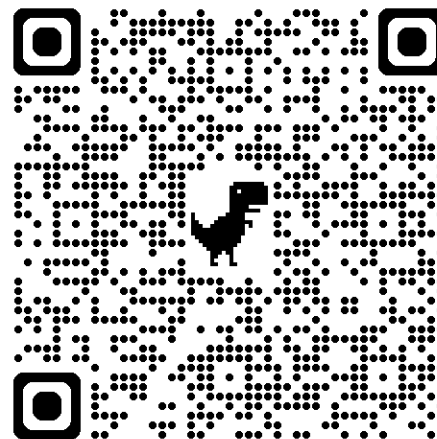
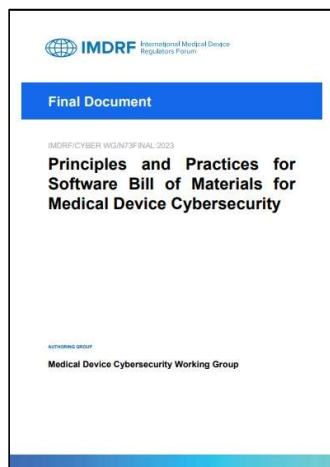
実戦・戦術レベルの情報共有

活動：24時間365日体制で、攻撃の予兆、マルウェアの解析結果、脆弱性情報などの脅威インテリジェンスを会員企業間でリアルタイムに共有する

2-3. 国際医療機器規制当局フォーラム(IMDRF)「医療機器サイバーセキュリティ向けソフトウェア部品表の原則と実践」 (2023年4月発行)

本書は、医療機器のサイバーセキュリティ向上を目的に、ソフトウェア部品表(SBOM)の作成や活用に関する基本原則と実践的なベストプラクティスをまとめた国際的なガイドラインです。医療機器のデジタル化や他社製コンポーネントへの依存が進む中、潜在的脆弱性と患者への健康被害リスクを低減するため、機器のライフサイクル全体を通じてソフトウェアの透明性を高めることが不可欠となっています。

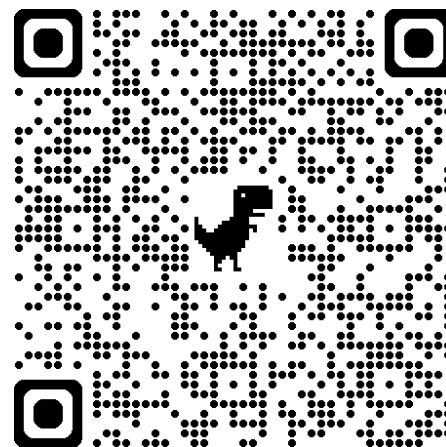
医療機器
メーカー
向け



2-4. 米国MITRE「ソフトウェア部品表(SBOM)データ正規化 における課題管理のための考慮事項」(2026年4月発行)

本書は、医療機器製造業者が大規模なSBOM管理で直面する「データ正規化」の課題解決に向けたホワイトペーパーです。進化するSBOM技術や組織変更に柔軟に対応するため、組織全体で一貫した命名法を用いてデータを集約できる「信頼できる単一の情報源(SoT)」の構築を推奨しています。適切なツール選定や、CPE・PURL等の基本属性をSoTで一元管理・自動化するための考慮項を提示しています。

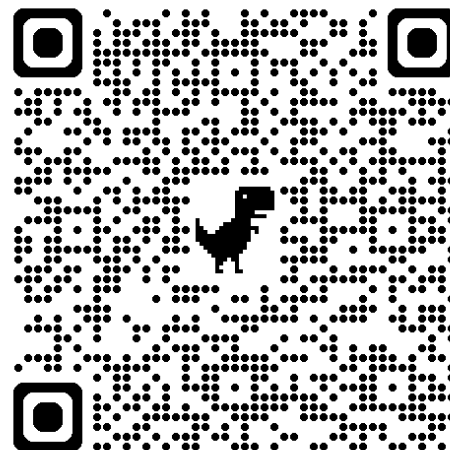
医療機器
メーカー
向け



2-5. 米国MITRE「進化する技術の時代における医療機器向けサイバーセキュリティリスク分析」(2026年4月発行)

本書は、進化する技術(クラウド、AI/ML、耐量子暗号(PQC))を組み込んだ医療機器を設計・調達する際のサイバーセキュリティリスク管理に関するディスカッションペーパーです。既存の実践方法を基礎とし、SBOMの活用や脅威モデリング、ガバナンス(契約やSLA)を段階的に適応させる重要性を提示しています。脆弱化を防ぎ、安全にアップデートし続けられる医療機器開発の必要性を説いています。

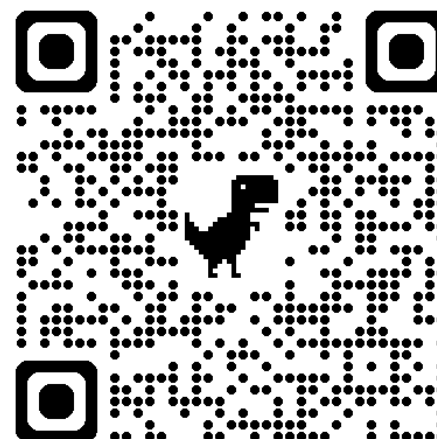
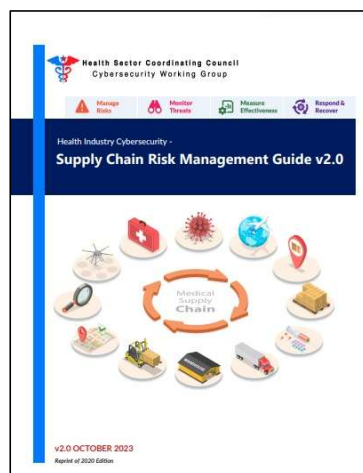
医療機器
メーカー
向け



2-6. 米国保健医療セクター調整委員会(HSCC) 「保健医療業界におけるサイバーセキュリティサプライチェーンリスク マネジメントガイド第2版(HIC-SCRiM v2.0)」 (2023年10月発行)

本書は、医療機関やそのサプライヤー向けに、複雑なサプライチェーンにおけるサイバーリスク管理の標準的な枠組みを示したものです。従来の「IT」に加え、医療機器や設備管理システム、クラウドサービスを網羅しています。組織の成熟度に合わせたリスク評価、契約時のセキュリティ要件、ソフトウェア部品表(SBOM)を活用した透明性の確保など、製品の導入から廃棄までのライフサイクル全般における具体的な実践方法を提示しています。

医療機関
向け



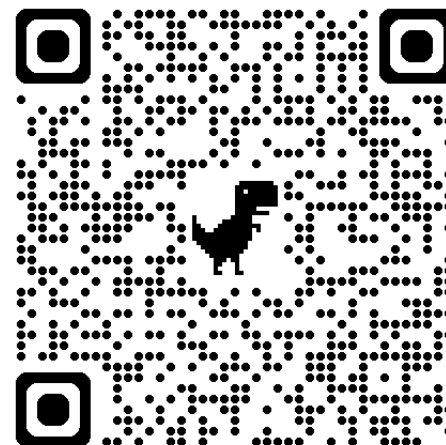
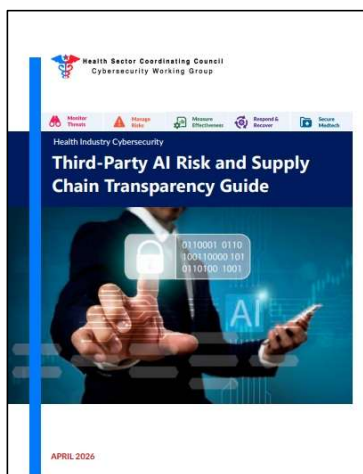
2-7. HIC-SCRiM v2.0 におけるSBOM

観点	SBOM の扱い
目的	ソフトウェア構成要素の透明性確保、脆弱性管理の迅速化
位置づけ	サプライチェーンリスク管理の基礎データ
関連フレームワーク	NISTサイバーセキュリティフレームワーク (特に ID.SC-1～SC-5)
契約	SBOM提供義務を契約条項に含めることを推奨
形式	SPDX / CycloneDX / SWID など標準形式を推奨
関連概念	VEX（脆弱性影響の有無を示す文書）
利用場面	脆弱性管理、インシデント対応、サプライヤー評価

2-8. 米国保健医療セクター調整委員会(HSCC) 「保健医療業界におけるサードパーティAIリスクとサプライチェーンの 透明性ガイド」(2026年4月発行)

本書は、医療機関(HDO)がサードパーティ製AIを導入する際のサイバーセキュリティリスクと、サプライチェーンの透明性確保に関する指針をまとめたものです。AI特有のリスク(データの偏りや不透明なアルゴリズム等)に対し、NIST等のフレームワークを用いた評価や、ライフサイクル全体の継続的なモニタリングを推奨しています。ベンダーとの責任共有モデルを構築し、リスクをリアルタイムで検知・軽減することで、安全な医療サービスの提供と信頼性の高いAI活用を目指す実務的な内容となっています。

医療機関
向け



2-9.サードパーティAIリスクとサプライチェーンの透明性ガイドの構成

- **エグゼクティブ・サマリー**
- **主要な推奨事項**
- **実装アプローチ**
- **行動喚起**
- **AIサードパーティリスクおよびサプライチェーン透明性のためのプロセス用語と定義**
- **AIサードパーティの対象範囲**
- **フェーズごとの詳細プロセス**
 - **フェーズ0：AIユースケースの正当化および戦略的評価**
 - **フェーズ1：ベンダー評価およびデューデリジェンス**
 - **フェーズ2：契約交渉および法的保護**
 - **フェーズ3：実装、統合、およびトレーニング**
 - **フェーズ4：継続的なモニタリングおよびパフォーマンス管理**
 - **フェーズ5：インシデント対応および復旧**
 - **フェーズ6：ライフサイクル終了(エンド・オブ・ライフ)および移行管理**
- **結論と本ガイドの活用方法**

(続き)

- 附表A：フェーズ0 AIユースケースの正当化テンプレートおよびリスクレベルの定義
- 附表B：AIサードパーティリスクに関するガバナンスポリシー
- 附表C：インベントリ管理
- 附表D：RACI（責任者：Responsible、説明責任者：Accountable、協業者：Consulted、報告先：Informed）マトリックス
- 附表E：商用契約条項のサンプル
- 附表F：事業提携契約（BAA）条項のサンプル
- 附表G：調達およびガバナンス・リスク・コンプライアンス（GRC）担当者向けAIベンダー評価質問項目
- 附表H：トレーニング修了チェックリストおよびカリキュラム
- 附表I：AIサードパーティプロバイダーにおける品質保証／検証／妥当性確認
- 附表J：参考文献

2-10. サードパーティAIサプライチェーンリスクマネジメントのライフサイクル

フェーズ	内容
<u>0. AI利用目的の正当化と戦略評価</u>	- AIを導入する理由・目的・期待効果を明確化する - リスクレベル(臨床影響、データ感度、依存度など)を初期評価する - AIを使うべきか、従来技術で代替可能かを判断する - 組織のAIガバナンス方針との整合性を確認する
<u>1.ベンダー評価とデューデリジェンス</u>	- ベンダーのセキュリティ姿勢・データガバナンス・モデル透明性を評価する - AIモデルの来歴(Lineage)、データ出所、依存コンポーネントを確認する - AI特有のリスク(合成データ悪用、推論攻撃、データ漏えい)を評価する - ベンダーの説明責任・監査可能性を確認する
<u>2.契約交渉および法的保護</u>	- AIモデル・データ・依存関係の透明性を契約で義務化する - 更新通知、モデル変更、再学習の影響を契約に明記する - 共有責任モデルを定義する - 事業提携者契約(BAA)や AI特有の条項を整備する
<u>3.実装、統合、およびトレーニング</u>	- AIシステムを安全に導入するための技術的統合 - アクセス制御、データフロー、API 管理、ログ設定を確立する - ユーザー教育(AIの限界、バイアス、誤用防止)を実施する - 組織のワークフローに合わせた安全な運用設計

(続き)

フェーズ	内容
<u>4.継続的なモニタリング およびパフォーマンス管理</u>	- モデル性能の監視(精度低下、ドリフト検知) - セキュリティ監視(推論攻撃、データ漏えい) - ベンダーからの更新通知の管理 - リスクレベルに応じた定期レビュー - AIの「ブラックボックス化」を防ぐための透明性維持
<u>5.インシデント対応 および復旧</u>	- AI特有のインシデント(モデル改ざん、データ漏えい、誤推論)に対応 - ベンダーとの連携による迅速な封じ込め - 影響範囲の特定(モデル、データ、依存サービス) - 復旧後の再評価と改善策の実装
<u>6.ライフサイクル終了 (EOL)および移行管理</u>	- モデルのサポート終了(EOL)に伴うリスク評価 - 代替モデルへの移行計画(データ移行、再学習、互換性確認) - 旧モデルの安全な停止・廃棄(API無効化、データ削除) - ベンダーのライフサイクル終了(EOL)通知義務と透明性の確保

2-11. ベストプラクティスのコンポーネント

コンポーネント	内容
1.ガバナンスポリシーの策定	・説明責任、データ取扱い、倫理的配慮、セキュリティ管理、インシデント報告を網羅する包括的なAIガバナンスポリシーの整備。
2.調達プロセスの強化	・ユースケースの正当化要件、データの来歴、バイアス軽減、セキュリティ管理、透明性に関する AI 特有の質問を含む強化された GRC(ガバナンス・リスク・コンプライアンス) 評価の実施。
3.契約および法的保護	・データ所有権、AI学習(トレーニング)制限、製品アップデート管理、性能基準、責任分担に関するモデル契約条項の整備 ・AI 特有の HIPAA コンプライアンスに対応した強化版事業提携者契約(BAA)条項の導入
4.インベントリおよび資産管理	・既存のAIシステムを発見・把握する体系的アプローチと、すべてのAIツール、アプリケーション、組み込み機能を継続的に追跡する仕組みの確立
5.品質保証および検証・バリデーション(QA/VV)	・サードパーティ製AIソリューションに対する構造化されたQA/VVフレームワークの構築(ベンダーのテスト文書、ステージング環境での検証、アップデート後の再バリデーション手順を含む)
6.対応および復旧計画	・AIベンダーとの統合的なインシデント対応体制、モデルのロールバック手順、レジリエンス要件の整備
7.ライフサイクル終了(EOL)管理	・AIシステムの移行管理、データ移行、安全な廃止(デコミッショニング)に関するプロセスの確立

2-12. サードパーティAIサプライチェーンリスクマネジメントにおけるAI BOMの役割

AI特有のガバナンス、リスク、コンプライアンス(GRC)評価

b) モデルの透明性と説明可能性(説明責任)

i) モデルアーキテクチャの文書化 (ドキュメンテーション)

ii) ソフトウェア部品表(SBOM)およびAI部品表(AI BOM) :
どの機能がAI対応(有効化)されているかのリスト、モデルの依存関係、およびサードパーティサービス。または、モデルのアーキテクチャ、学習データ、依存関係、外部サービス、およびサードパーティのコンポーネントについて記述した同等の文書

iii) ユースケースの重要度に応じた説明可能性の機能

iv) 決定境界と確信度の閾値

v) 人間による監視メカニズムおよび(手動による)オーバーライド機能

vi) バージョン管理とモデルの系譜(リネージ)の追跡

2-13. サードパーティAIサプライチェーンリスクマネジメントにおけるAI BOMとSBOMの役割の比較

観点	AI BOMの役割	SBOMの役割
目的	AIモデルの透明性・説明可能性・リスク把握	ソフトウェア構成要素の可視化と脆弱性管理
対象範囲	AIモデル、学習データ、推論パイプライン、依存API、クラウドAIサービス	ソフトウェアパッケージ、ライブラリ、OSS、依存関係
モデル情報	モデル種別、アーキテクチャ、モデル来歴、更新履歴	---
データ情報	学習データの出所、品質、バイアス、データガバナンス	---
AI 特有のリスク	データ漏えい、推論攻撃、モデルドリフト、合成データ悪用	---
依存コンポーネント	外部 API、AI サービス、推論エンジン、クラウド依存	ライブラリ、OSS、バイナリ依存
脆弱性情報	AI 特有の脆弱性（モデル抽出、データポイズニング等）	CVE ベースの既知脆弱性
運用情報	モデル監視、ドリフト検知、再学習プロセス	ソフトウェア更新・パッチ情報
ライフサイクル管理	AI モデルの継続的評価、再学習、EOL 管理	ソフトウェアのバージョン管理とEOL
契約での要求	AI モデル透明性、データ開示、モデル更新通知	SBOM 提供、更新時の SBOM再提出
標準化状況	まだ初期段階(HSCC, NIST AI RMF が方向性を提示)	SPDX, CycloneDX など標準規格あり

AGENDA

- 3. まとめ・Q&A



<https://www.linkedin.com/in/esasahara>

<https://www.facebook.com/esasahara>

<https://twitter.com/esasahara>